Quiz — TOTP verify

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

Complete after `../readings/totp_verify.md`. Complete the quiz, then check the separate answer key.

1. Why does TOTP need both a shared secret **and** a time-derived counter — what fails if you only had a static shared secret?

2. How does TOTP relate to **HOTP**, and why does that design choice matter for servers that cannot store a counter per user device?

3. Why does `verify` often accept a small **window**? What problem does that *not* solve?

4. Why prefer a library (e.g. `pyotp`) over hand-rolling **HMAC** in a short challenge?

5. Scenario: production MFA ships with a verify window but no rate limit and no used-code store. What two attacks remain easy?

6. Scenario: A user's phone clock is 45 seconds ahead of the server. With a 30-second step and `valid_window=1`, might a just-generated code still verify? Briefly why.